CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad **YUSUF DURSUN · 230541104** Grup **GÜNDÜZ B** Tarih

Senaryo: Saat 10:15. Vincin servis hesabına gece 03:00'te tanınmayan bir konumdan girilmiş. PLC konfigürasyonu ve yük ölçüm kalibrasyonu değişmiş olabilir; aşırı yük ve limit parametreleri henüz doğrulanmadı. Vinç çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey zaman ve kanıttır. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır. **Not:** CRA bildirim yükümlülüğü ürünün **üreticisindedir (Çakmak Vinç)**; kullanıcı olarak biz üreticiyi hemen bilgilendirir ve gereken bilgiyi sağlarız.

Görev — zaman çizgisini doldurun

1 10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?

Aranacaklar: bakım/elektrik sorumlusu, BT/OT güvenlik sorumlusu, İSG uzmanı, üretici Çakmak Vinç servisi; bilgi için fabrika müdürü.
İlk üç eylem:

- **1 · Önce emniyet:** Askıdaki yükü yavaş hızda güvenli şekilde yere indir (havada bırakma), alanı boşalt, ana şalteri kapat, kilitle–etiketle (LOTO, "kullanılamaz"). Emniyet doğrulanmadan çalıştırma yok.
- **2 · İzole et:** 4G uzak bakım modülünün bağlantısını ayır (cihazın enerjisini kesme — bellekteki kanıt silinir), Wi-Fi'yi kapat.
- **3 · Kanıtı koru:** Olay kaydını saatleriyle başlat, ekran fotoğrafları al; kimse reset, yeniden yükleme veya kalibrasyon yapmasın.

2 İlk 2 saat: Makine güvende mi — nasıl doğrularsınız? Hangi kanıt korunur? Hangi hesap kapatılır?

Doğrulama: Safety PLC checksum'ını validasyon kaydındaki değerle karşılaştır; aşırı yük eşiği ve kalibrasyon katsayılarını onaylı yedekle karşılaştır; bilinen test ağırlığıyla yük okumasını ve aşırı yük kesmesini doğrula; kaldırma/ray sonu limitlerini yavaş hızda test et; fren tutma testi; telsiz ve pano acil stoplarını test et.
Korunacak kanıt: 4G modül, VPN ve güvenlik duvarı logları, PLC/Safety PLC audit logları, **değiştirmeden önce** alınmış program/parametre kopyası, HMI olay/alarm geçmişi, telemetri (yük, hareket kayıtları) — hash'lenip gözetim zinciriyle saklanır.
Hesaplar: admin/servis hesabı devre dışı; paylaşılan parolalar değişir; üretici uzak erişimi askıya alınır, kişisel hesaplar MFA ile yeniden açılır.

3 24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?

Üreticinin erken uyarısı için ona ileteceğimiz bilgiler: ne oldu (servis hesabıyla yetkisiz erişim), tespit zamanı, etkilenen ürün ve firmware sürümü, kötü niyet şüphesi, aktif istismar edilen bir zafiyet olup olmadığı, başka vinçlere/müşterilere yayılma ihtimali, alınan acil önlemler. Üretici bunu koordinatör CSIRT'e ve ENISA'ya tek raporlama platformu üzerinden iletir.

4 72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?

- **Üretici (Çakmak Vinç) PSIRT:** kök neden analizi (ör. admin/admin + internete açık 4G modül veya bir zafiyet), etki değerlendirmesi, düzeltici önlem/yama, bildirimin gönderilmesi ve diğer müşterilerin uyarılması.
- **Biz (kullanıcı):** loglar, kanıtlar, değişen parametrelerin karşılaştırması, yük ve limit test sonuçları.
- **OT/BT güvenlik:** adli inceleme, geçici önlemler.
- **Bakım + İSG:** emniyet doğrulaması ve yeniden devreye alma onayı.
- **Yönetim:** kararlar, iç/dış iletişim.

5 14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?

(CRA: aktif istismar edilen zafiyette düzeltici önlem hazır olduktan sonra en geç 14 gün; ciddi olayda bildirimden sonra 1 ay.)

- 4G modül, VPN ve güvenlik duvarı erişim logları; oturum kayıtları
- PLC/Safety PLC audit logları, olay öncesi/sonrası program ve kalibrasyon kopyaları, checksum karşılaştırmaları
- HMI alarm/olay geçmişi, yük ve hareket telemetrisi
- Yük testi, limit, fren ve acil stop testlerinin imzalı kayıtları; yeniden devreye alma tutanağı
- Olay zaman çizelgesi, iletişim kayıtları, hesap/parola değişiklikleri, yama ve önlem kayıtları

En sık hata: *"Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt.*

📄 Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur.